



无线网络安全

第五章：无线个域网

第五章：无线个域网

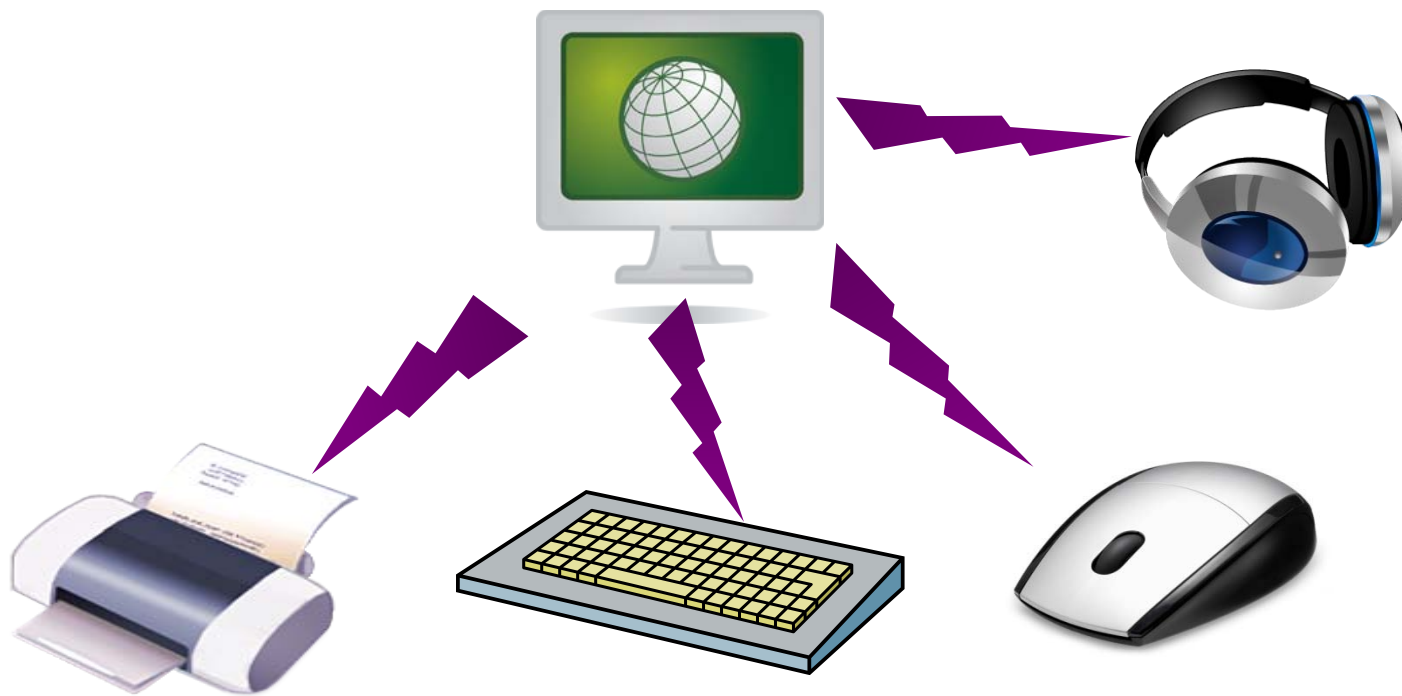


无线个域网概述

- ❖ 无线个域网(Wireless Personal Area Network, WPAN)是为了实现活动半径小、业务类型丰富、面向特定群体、无线无缝的连接而提出的新兴无线通信网络技术。WPAN能够有效地解决“最后的几米电缆”的问题，进而将无线联网进行到底。

无线个域网概述

- ❖ 无线个域网通过短距离的无线电，将一台计算机或者智能部件连接起来



无线个域网概述

- ❖ WPAN的范围通常只有几米，用于互联计算机、智能收集、计算机外围设备、以及用于连接到另一个网络的设备(如Internet网关)
- ❖ 常用技术(电缆替换技术):
 - 蓝牙（无需驱动程序）
 - 红外数据协会（IrDA）标准
 - ZigBee（IEEE 802.15.4）
 - RFID（射频识别）
 - UWB（超宽带无线技术）
 - HomeRF
 - 为家庭用户建立具有互操作性的话音和数据通信网
- ❖ IEEE 802.15工作组针对无线个域网，以上述技术为基础，进行无线个域网的标准化工作



无线个域网概述

❖ IEEE802.15标准

- 802.15.1: 以既有蓝牙标准为基础，制定蓝牙无线通信规范的正式标准
- 802.15.2: 为802.11和802.15(两者使用相同的频段)开发共存的推荐规范
- 802.15.3: 开发比802.11设备更低成本和低功耗的设备标准，但有明显的高速率
- 802.15.3a: 在同样的MAC层上提供比802.15.3更高的数据率
- 802.15.4: 开发一个非常低成本、非常低功耗的比802.15.1数据率要低的设备标准

无线个域网概述

IEEE802.15协议体系结构

逻辑链路控制（LLC）

**802.15.1
MAC
(蓝牙)**

**802.15.3 MAC
(低成本 低功耗
高速率)**

**802.15.4 MAC
(低成本 低功耗
低速率)**

**802.15.1
2.4GHz
1Mb/s**

**802.15.3
2.4GHz
11,22,33,
44,55Mb
/s**

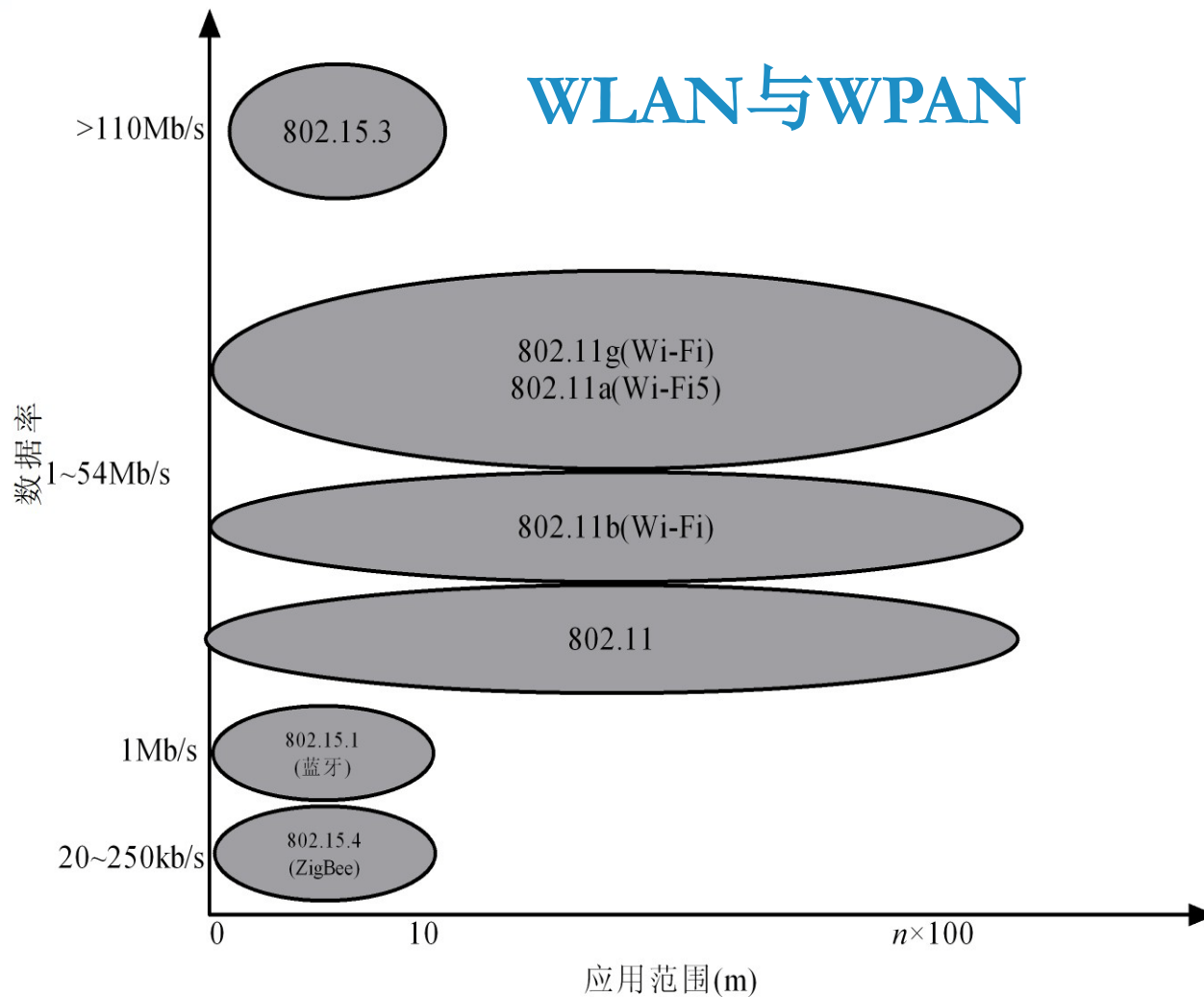
**802.15.3
a
>110Mb/
s**

**802.15.4
868MHz
20kb/s**

**802.15.4
915MHz
40kb/s**

**802.15.4
2.4GHz
250kb/s**

无线个域网概述



无线个域网概述

IEEE 802.15.3

802.15.3: 关注高速率WPAN的开发，如应用：

- 将数字照相机连接到打印机上
- 笔记本与投影机的连接
- 摄像机图像显示在电视中
- 远程取景器连接到视频或数码相机上

这些应用有如下要求：

- 短距离传输（10m）
- 高流通量（超过20Mb/s）
- 低功耗（靠电池）
- 简易的连接

这些在WLAN中并不容易满足，所以开发了新的标准IEEE 802.15.3

- 802.15.3可以得到11~55Mb/s的速度
- IEEE 802.15.3a提出了更高速率(110Mb/s或更高)

蓝牙技术简介

❖ 蓝牙

- ❖ 1994年: 爱立信决定开发一种低功耗、低成本的无线接口。该公司的工程师J. Haartsen博士和S. Mattisson博士发明了蓝牙技术(IEEE 802.15.1)
- ❖ 名称“蓝牙”（Bluetooth）源自10世纪丹麦国王Harald Blåtand（意为“蓝牙国王”），象征技术统一通信领域的愿景。其Logo融合卢恩字母H（*）和B（ᛒ），代表国王名字首字母缩写



蓝牙技术简介

❖ 蓝牙产生的背景

- 1998年5月，爱立信、诺基亚、东芝、IBM和Intel公司等五家著名厂商，在联合开展短程无线通信技术的标准化活动时提出了蓝牙技术，其宗旨是提供一种短距离、低成本的无线传输应用技术。
- 这五家厂商还成立了蓝牙特别兴趣组，以使蓝牙技术能够成为未来的无线通信标准。
- ◆ 芯片霸主Intel公司负责半导体芯片和传输软件的开发
- ◆ 爱立信负责无线射频和移动电话软件的开发
- ◆ IBM和东芝负责笔记本电脑接口规格的开发

蓝牙技术简介

❖ 蓝牙产生的背景

- 1999年下半年，著名的业界巨头微软、摩托罗拉、三星、朗讯与蓝牙特别小组的五家公司共同发起成立了蓝牙技术推广组织，从而在全球范围内掀起了一股“蓝牙”热潮。
- 全球业界即将开发一大批蓝牙技术的应用产品，使蓝牙技术呈现出极其广阔的市场前景，并预示着21世纪初将迎来波澜壮阔的全球无线通信浪潮。

蓝牙技术简介

❖ 蓝牙技术的发展历程

❖ 早期探索（1999-2003年）

- ❖ 蓝牙1.0（1999年）：首个商用标准，传输速率约723 Kbps，通信距离10米，但存在兼容性问题。

- ❖ 蓝牙1.1/1.2（2001-2003年）：优化抗干扰能力，支持IEEE 802.15.1标准，奠定短距通信基础。

❖ 性能提升（2004-2009年）

- ❖ 蓝牙2.0+EDR（2004年）：引入增强数据速率（EDR），传输速度提升至3 Mbps，支持双工通信（如同时传输文件与播放音频）

- ❖ 蓝牙3.0+HS（2009年）：结合Wi-Fi技术实现高速传输（24 Mbps），扩展至高清音频和文件共享场景

蓝牙技术简介

❖ 蓝牙技术的发展历程

❖ 低功耗革命（2010-2016年）

- ❖ 蓝牙4.0（2010年）：首次集成低功耗（BLE）技术，功耗降低90%，推动可穿戴设备与物联网发展。
- ❖ 蓝牙5.0（2016年）：传输距离扩展至300米，速度提升至2 Mbps，新增室内定位功能，支持车联网等复杂场景。

❖ 持续优化（2020年代）

- ❖ 蓝牙5.3/5.4（2023-2024年）：增强音频编码（如LC3）、广播音频（Auracast™）和信道探测技术，提升多设备连接稳定性与音质。

蓝牙技术简介

❖ 蓝牙技术优点

- ❖ 蓝牙是一种低带宽、短距离、低功耗(对人体伤害小)的数据传输技术
- ❖ 工作在2.4GHz频段，通信距离在10米之内；数据速率为1Mb/s
- ❖ 现在几乎一切东西都支持蓝牙，从键盘到操作系统，耳机，手机
- ❖ 不需任何电缆、不需更改配置、不需进行故障诊断即可建立连接
- ❖ 具有很强的移植性，可应用于多种通信场合，如WAP、GSM(全球移动通信系统)、DECT(欧规数字无绳通信)等，引入身份识别后可以灵活地实现漫游
- ❖ 蓝牙集成电路简单，成本低廉，实现容易，易于推广

蓝牙技术简介

❖ 蓝牙的干扰

- ❖ 2.4GHz的ISM频段是对所有无线电系统开放的频段，因此使用该频段都会遇到不可预测的干扰源

- 无绳电话

- 微波炉

- ❖ 蓝牙技术特别设计了快速确认和跳频方案以确保链路的稳定

- 蓝牙跳频更快(1600跳/s)

- 数据分组更短

蓝牙技术简介

❖ 蓝牙标准文档构成

- ❖ 核心规范(core specifications): 描述了从无线电接口到链路控制的不同层次蓝牙协议体系结构的细节
 - 如相关技术的互操作性等
- ❖ 概要规范(profile specifications): 考虑使用蓝牙技术支持不同的应用。每个概要规范讨论在核心规范中定义的技术, 以实现特定的应用模型(Usage Model)
 - 目的: 定义互操作性的标准, 使来源于不同厂商、声称支持给定应用模型的产品能一起工作

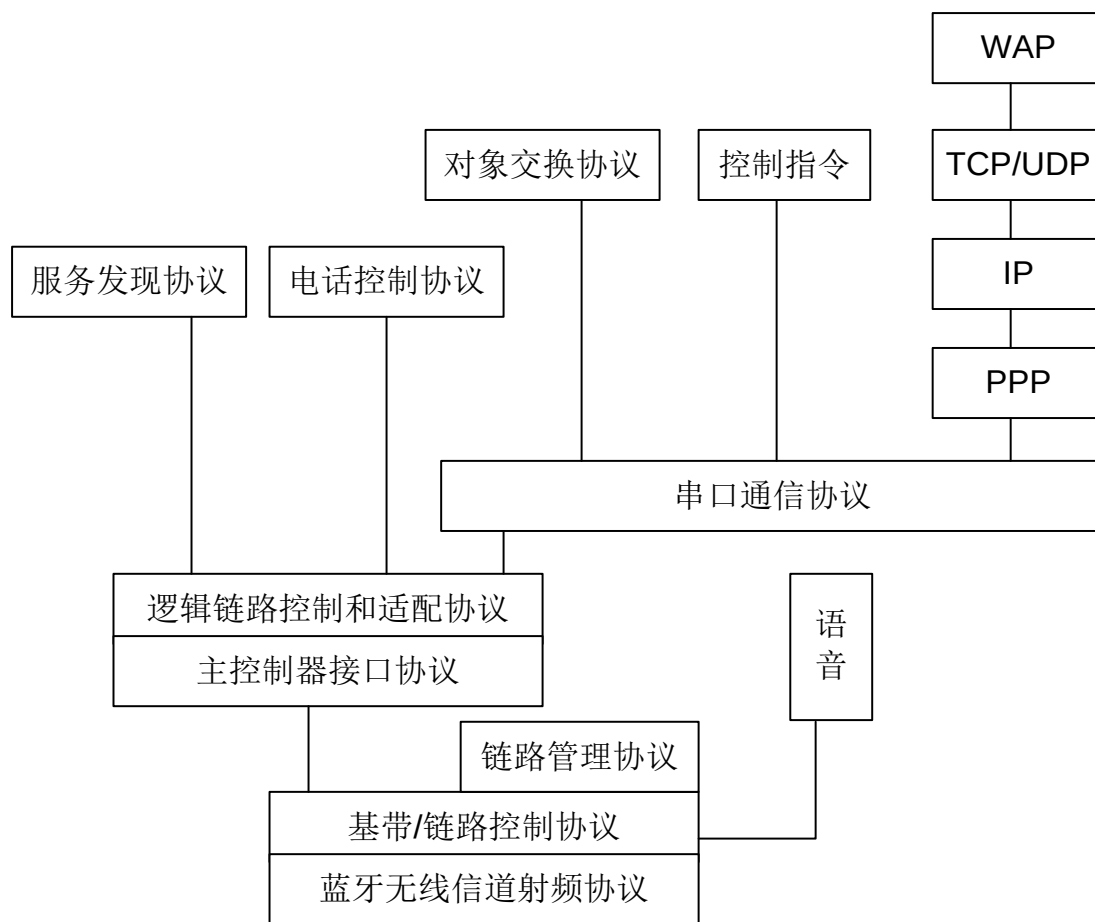
蓝牙技术简介

❖ Bluetooth协议

- 蓝牙标准包括两大部分：核心（Core）部分定义了蓝牙的技术细节；轮廓（Profile）部分定义了在各种应用中协议栈的组成。
- 蓝牙标准主要定义的是底层协议，同时为保证和其他协议的兼容性，也定义了一些高层协议和相关接口。
- 从ISO的OSI七层协议标准来看，蓝牙标准主要定义的是物理层、链路层和网络层的结构。

蓝牙技术简介

蓝牙应用协议栈



蓝牙技术简介

❖ 蓝牙协议栈的组成

➤ 射频协议（RF/Radio Protocol）

- ◆ 定义了蓝牙发送器和接收器的各个参数，包括发送器的调制特性、接收器的灵敏度、抗干扰性能、互调特性和接收信号强度指示等。

➤ 基带+链路控制协议（Baseband/LC Protocol）

- ◆ 定义了基带部分协议和其他低层链路功能，是蓝牙技术的核心。

➤ 链路管理协议（Link Manager Protocol, LMP）

- ◆ 用于链路的建立、安全和控制，为此LMP定义了许多功能。

➤ 主机控制器接口（Host Controller Interface, HCI）协议

- ◆ 描述了主机控制器接口功能在蓝牙中起着中间层的作用：向下给链路控制器协议和链路管理协议提供接口，向上给逻辑链路控制和适配协议提供接口，提供一个访问蓝牙基带的统一方法。

蓝牙技术简介

❖ 蓝牙协议栈的组成

➤ 逻辑链路控制和适配协议

- ◆ 支持高层协议复用、帧的组装和拆分、传送QoS信息。提供面向连接和非连接两种业务。

➤ 服务发现协议

- ◆ 如何发现蓝牙设备所提供服务的协议，使高层应用能够得知可提供的服务。在两个蓝牙设备第一次通信时，需要通过SDP来了解对方能够提供何种服务，并将自己可提供的服务通知对方。

➤ 高层协议

- ◆ 包括串口通信协议、电话控制协议、对象交换协议、控制命令、电子商务标准协议和PPP、IP、TCP、UDP等相关的Internet协议及WAP协议。

蓝牙安全

❖ Bluetooth链路层安全

➤ 安全模式

◆ 非安全模式

◆ 业务层安全模式

◆ 链路层安全模式

蓝牙安全

- ❖ Bluetooth链路层安全
- ❖ 安全模式
- ◆ 非安全模式
- ✓ 不采用信息安全管理和执行安全保护，设备运行一般应用时使用。该模式下，设备避开链路层的安全功能，可访问不含敏感信息的数据库。

蓝牙安全

❖ Bluetooth链路层安全

➤ 安全模式

◆ 业务层安全模式

- ✓ 蓝牙设备在L2CAP层建立信道之后采用信息安全管理并执行安全保护。这种安全机制建立在L2CAP及其之上的协议中，该模式可为多种应用提供不同的访问策略，可并行运行安全需求不同的应用。

蓝牙安全

❖ Bluetooth链路层安全

➤ 安全模式

◆ 链路层安全模式

- ✓ 在LMP层建立链路的同时就采用信息安全管理和执行安全保护，该安全机制建立在芯片中和LMP协议基础上。在该模式中，链路管理器（LM）在同一层面上对所有的应用强制执行安全措施。

蓝牙安全

❖ Bluetooth链路层安全

➤ 安全模式

◆ 业务层安全模式与链路层安全模式的本质区别

- ✓ 业务层安全模式下的蓝牙设备在信道建立以前启动安全性过程，也就是说，他安全性过程在较高层协议进行；
- ✓ 链路层安全模式下的蓝牙设备在信道建立以后启动安全性过程，也就是说，它的安全性过程在较低层协议进行。

蓝牙安全

❖ Bluetooth链路层安全

➤ 设备信任关系

◆ 设备对于访问的应用有以下两种可能

✓ 信任关系

✓ 不信任关系

◆ 信任设备可以无限制访问所有应用，而不信任设备对服务的访问是受限制的

蓝牙安全

❖ Bluetooth链路层安全

➤ 应用安全等级

◆ 应用存在以下3个安全等级：

- ✓ 需要授权和鉴权的服务
- ✓ 仅仅需要鉴权服务
- ✓ 对所有设备开放的服务

蓝牙安全

❖ Bluetooth链路层安全

➤ 安全信息单元（实体）

◆ 在链路层使用以下4个实体（Entity）来建立或维持安全性

◆ 蓝牙设备地址

✓ 每个蓝牙设备唯一的48比特的地址。

◆ 链路密钥

✓ 是身份认证和加密的重要参数，128比特。通过E21或E22算法产生。

◆ 加密密钥

✓ 用于加密的8~128位密钥，用Kc表示，由E3算法产生。

◆ 随机数

✓ 由蓝牙设备产生的经常改变的128位伪随机数。鉴权和加密密钥在初始化时得到，它们是不公开的。

蓝牙安全

❖ Bluetooth链路层安全

➤ 链路密钥的种类

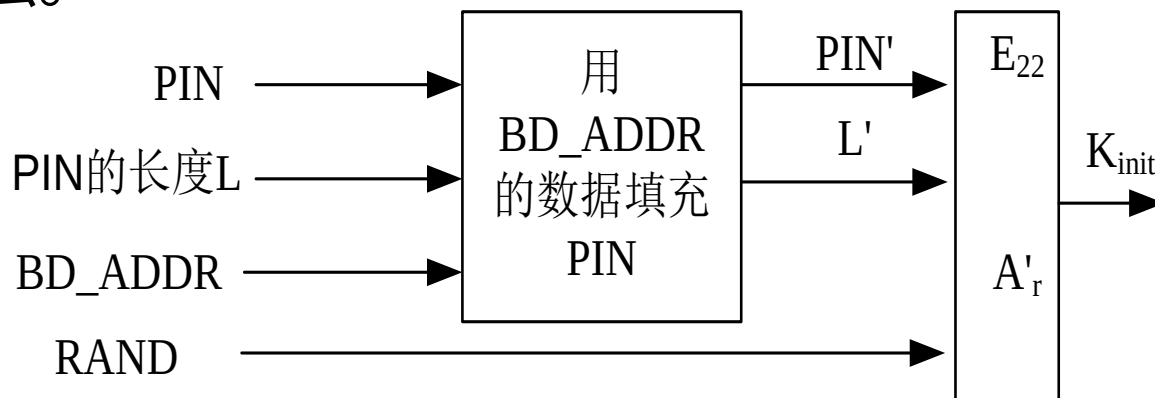
- ◆ 在蓝牙系统中，按生命周期区分，链路分为永久密钥、半永久密钥和临时密钥。按应用的运行阶段和应用模式，蓝牙系统定义了4种链路密钥
- ✓ 单元密钥 K_a ，在单元A安装蓝牙设备时产生。
- ✓ 组合密钥 K_{ab} ，产生于单元A和B，用于需要更高的安全性时。
- ✓ 主密钥 K_{master} ，用于主设备传送信息给多个设备，临时代替当前链路密钥。
- ✓ 初始密钥 K_{init} ，用于保护传输中的初始化参数。

蓝牙安全

❖ Bluetooth链路层安全

➤ 初始密钥的产生

- ◆ Kinit的值以申请者的蓝牙设备地址BD_ADDR、一个PIN（个人身份码）码、PIN码的长度和一个随机数RAND作为参数，通过E22算法产生。如下图所示，当PIN的长度少于16个八进制数时，可以通过填充蓝牙设备地址使其增大，在E22的内部输入端是一个128位的随机数RAND、PIN'和L'，随后E22用加密函数A'r产生初始密钥Kinit。加密函数A'r主要基于SAFER+（Secure And Fast Encryption Routine）加密算法。



蓝牙安全

❖ Bluetooth链路层安全

➤ 安全机制

- ◆ 蓝牙的链路层安全是通过**匹配、鉴权**进而加密完成的。密钥的建立是通过双向通信来实现的。鉴权和加密可以在物理连接中实现，也可以通过上层的协议来实现。
- ◆ **匹配 (Pairing)**。是蓝牙安全最具特色的地方。两台蓝牙设备试图连接时，个人识别码 (PIN) 和一个随机数经必要信息交换和计算创建初始密钥Kinit，此过程称为匹配。

蓝牙安全

❖ Bluetooth链路层安全

➤ 安全机制

◆ 鉴权

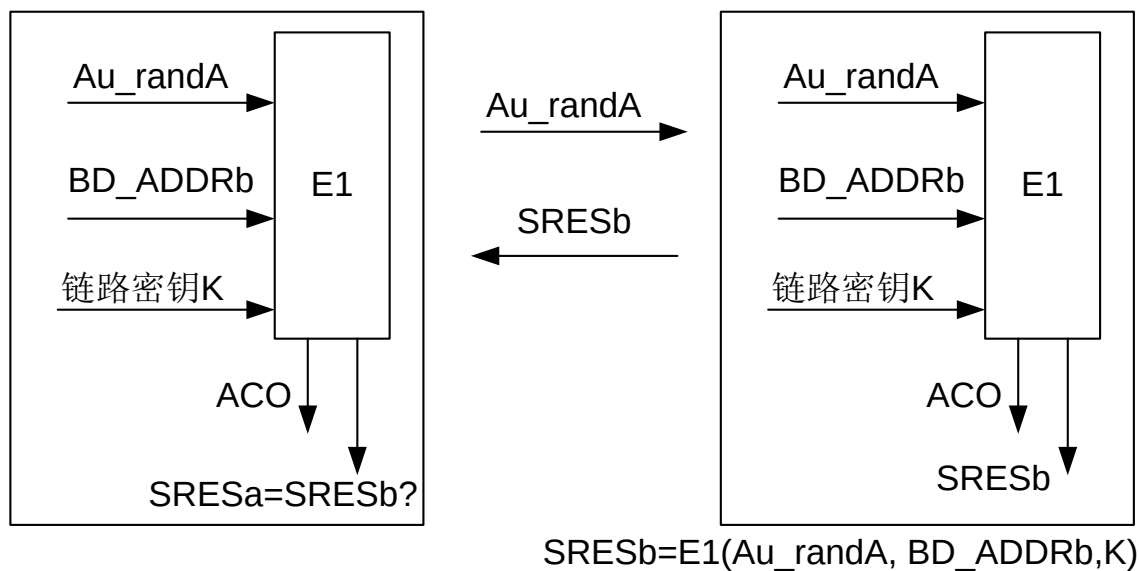
- ✓ 蓝牙实体的鉴权采用“挑战——应答”方式，当链路密钥存在时采用LMP鉴权，当密钥不存在时采用LMP连接，LMP鉴权过程如下图所示。
- 验证方（使用鉴权码E1）向申请者发送“挑战”，要求对随机输入Au_randA进行验证
- 申请方返回一个结果SRES到验证方，E1的输入包括申请方的Au_randA和BD_ADDRb。使用该地址是为了防止简单的反射攻击。
- 节点A和节点B共享的密钥是当前的链路密钥。在蓝牙系统中，验证方不一定是主节点，而由应用指定。
- 鉴权成功以后，产生了鉴权编码补偿（ACO），以用于加密密钥的产生。若进行了多次鉴权则保留最后一次鉴权时的ACO。

蓝牙安全

❖ Bluetooth链路层安全

➤ 安全机制

◆ 鉴权



蓝牙的鉴权过程

蓝牙安全

❖ Bluetooth链路层安全

➤ 安全机制

◆ 鉴权

✓ 鉴权函数

□ E1使用了一个名为SAFER+的加密函数，该算法是分组加密算法SAFER-SK128的一个增强版本，SAFER+加密的明文分组为128位。

□ 加密密钥可以为128位、192位和256位。在蓝牙中使用了128位密钥，最后分组密码将被表示为 E_r 函数，该函数把一个128位的密钥和一个128位输入映射到一个128位的输出。

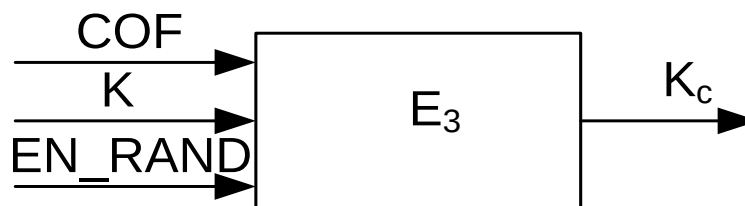
蓝牙安全

❖ Bluetooth链路层安全

➤ 安全机制

◆ 加密。

- ✓ 当设备进入加密模式时，需要产生加密密钥，每进入一次加密模式，都会产生一个新的加密密钥。主节点在进入加密模式之前发送一个随机数，加密字 K_c 由E3算法产生，如下图所示，输入参数为96位的加密偏移数（COF）、128位的RAND和当前链路字 K 。



蓝牙加密密钥 K_c 的产生

蓝牙安全

❖ Bluetooth链路层安全

➤ 安全机制

◆ 加密

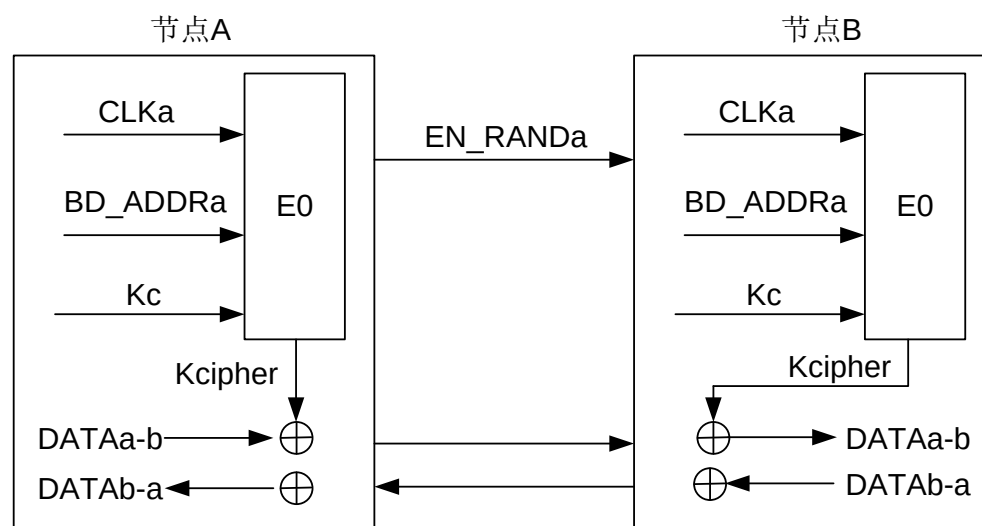
- ✓ 加密过程如下图所示。加密使用流加算法，加密比特与数据流进行逐位的模2加，之后发送到空中接口。
- ✓ 净荷的加密是在CRC校验之后，在FEC编码之前进行的。每个分组的净荷分别进行加密。
- ✓ 加密算法E0利用主节点地址、26bit的主节点实时时钟和加密密钥 K_c 作为输入。
- ✓ 在E0算法内，加密密钥变成另外一份密钥 K'_c （如果密钥的长度小于16，则修正为 K'_c ）密钥的最大有效长度是1~16内之间固定的任何数。
- ✓ 实时时钟随着时隙增加，每当启动一个新的分组发送，E0算法就重新初始化一次，在两次发送之间，CLK（时钟）至少有1bit发生变化，这样，在每次初始化之后都生成一个新的密钥流。

蓝牙安全

❖ Bluetooth链路层安全

➤ 安全机制

◆ 加密



加密过程

蓝牙安全

❖ Bluetooth链路层安全

➤ 链路层安全存在的问题

- ◆ 蓝牙地址具有唯一性，容易泄露使用者的个人隐私。
- ◆ PIN码是一个4位十进制数，它参与链路密钥和加密密钥的生成，易被穷举攻破。
- ◆ 蓝牙标准的安全体系结构只对设备鉴权，不对用户鉴权。
- ◆ 设备一旦被偷走，就可冒充原使用者进入蓝牙网络。
- ◆ 另外，现有的安全机制无法满足组建复杂的无线网络的需求。

ZigBee技术简介

❖ ZigBee发展历程

- 2000年12月，IEEE成立了IEEE 802.15.4工作组，致力于开发一种可应用在固定便携或移动设备上的低成本低功率及多节点的低速无线个域网技术标准，但是该工作组值专注于底层，要达到产品的互操作和兼容，还需要定义高层的规范。
- 2001年8月，美国霍尼韦尔等公司发起成立了ZigBee联盟，他们提出的ZigBee技术被确认为IEEE802.15.4标准。

ZigBee技术简介

❖ ZigBee发展历程

- ZigBee的标准化组织包括IEEE 802.15.4工作组和ZigBee联盟，IEEE 802.15.4（TG4）工作组制定的IEEE 802.15.4标准仅处理MAC层和物理层协议，而由ZigBee联盟所主导的ZigBee标准定义了网络层、安全层、应用层和各种应用产品的资料或规范，并对其网络协议和应用编程接口（API）进行了标准化。
- 2003年10月，IEEE发布了IEEE Std 802.15.4-2003标准；
- 2004年12月，ZigBee1.0标准正式公布。
- 值得注意的是，ZigBee提供了高可靠性的安全服务，它的安全服务所提供的方法包括密码建立、密码传输、帧保护和设备管理。这些服务构成了一个模块用于实现ZigBee设备的各类安全策略。

ZigBee技术简介

❖ ZigBee技术的特点

ZigBee技术不仅具有低成本、低功耗、低速率、低复杂度的特点，而且具有可靠性高、组网简单、灵活的优势。ZigBee技术和其他无线通信技术相比具有以下特点：

➤ 低功耗

- ◆ 由于ZigBee的传输速率低，发射功率仅为1mW，而且采用了休眠模式，功耗低，因此ZigBee设备非常省电。据估算，ZigBee设备仅靠两节5号电池就可以维持长达6个月到2年的使用时间。

➤ 成本低

- ◆ ZigBee模块的成本低廉，且ZigBee协议是免专利费的。

ZigBee技术简介

❖ ZigBee技术的特点

➤ 时延短

- ◆ 通信时延和从休眠状态激活的时延都非常短，典型的搜索设备时延为30ms，蓝牙需要3~10s，Wi-Fi需要3s；休眠激活的时延是15ms，活动设备信道接入的时延为15ms。因此ZigBee技术适用于对时延要求苛刻的无线控制应用。

➤ 低速率

- ◆ ZigBee运作在20~250kb/s的较低速率，分别提供250kb/s（2.4GHz）、40kb/s（915MHz）和20kb/s（868MHz）的数据吞吐量，满足低速率传输数据的应用需求。

➤ 近距离

- ◆ 传输范围一般介于10~100m之间，在增加发射功率之后，亦可增加到1~3km（相邻节点间的距离）。

ZigBee技术简介

❖ ZigBee技术的特点

➤ 网络容量大

- ◆ 一个星形结构的ZigBee网络最多可以容纳254个从设备和一个主设备，而且网络组成灵活。一个区域内最多可以同时存在100个独立而且相互重叠覆盖的ZigBee网络。

➤ 可靠性强

- ◆ 采用了碰撞避免策略，同时为需要固定带宽的通信业务预留了专用时隙，避开了发送数据的竞争和冲突。MAC层采用了完全确认的数据传输模式，每个发送的数据包都必须等待接收方的确认信息。如果传输过程中出现问题可以进行重发。

ZigBee技术简介

❖ ZigBee技术的特点

➤ 安全性较强

◆ ZigBee提供了基于循环冗余校验（CRC）的数据包完整性检查功能，支持鉴权和认证

➤ 免执照频段

◆ 使用工业科学医疗(ISM)频段，915MHz(美国)，868MHz(欧洲)，2.4GHz(全球)

ZigBee技术简介

❖ ZigBee与其他近距离无线通信技术的比较

➤ Bluetooth

➤ Bluetooth特殊兴趣组在1998年成立。其工作频率为2.4GHz，有效范围大约在10m半径内。Bluetooth列入了IEEE 802.15.1，规定了包括PHY、MAC、网络层和应用层等集成协议栈。Bluetooth对每个“Piconet（微微网）”只能配置7个节点，制约了在多节点网络中的应用。

ZigBee技术简介

➤ ZigBee与其他近距离无线通信技术的比较

◆ Wi-Fi (IEEE 802.11)

- ✓ IEEE 802.11的最初规范是在1997年提出，其工作频率也是2.4GHz，其中IEEE 802.11b带宽为11Mb/s。Wi-Fi规定了协议的物理（PHY）层和媒体接入控制（MAC）层，并依赖TCP/IP作为网络层。由于其优异的带宽是以大功耗为代价，因此大多数便携Wi-Fi装置都需要常规电池。这些特点限制了它在工业场合的应用。

◆ IrDA

- ✓ 红外线数据协会成立于1993年。IrDA是一种利用红外线进行点对点通信的技术。IrDA标准的无线设备传输速率可达16Mb/s。具有移动通信所需的体积小、功耗低、连接方便、简单易用、成本低廉的特点。只能在两台设备之间连接，且存在视距角度等问题。

ZigBee技术简介

❖ ZigBee与其他近距离无线通信技术的比较

	Bluetooth	Wi-Fi	IrDA	ZigBee
系统开销	较大	大	小	小
电池寿命	较短	短	长	最长
网络节点	7	30	2	255/65000+
物理范围	10m	100m	定向1m	1-100m+
传输率	1Mb/s	11Mb/s	16Mb/s	20/250kb/s
传输介质	2.4GHz射频	2.4GHz射频	980nm红外	2.4GHz射频

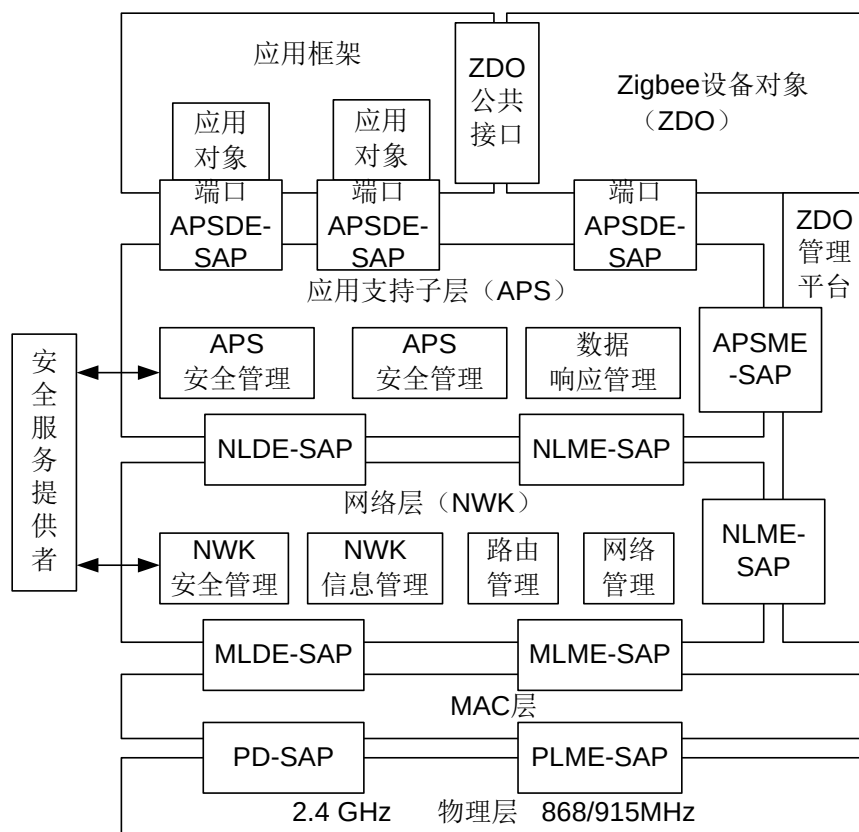
4种近距离无线通信技术的比较

红外线频率：10的12次到14次方 1太赫（1THz 10的12次方 Hz）= 1000GHz
速度=波长*频率

ZigBee安全

❖ ZigBee安全体系结构

➤ ZigBee协议栈的体系结构如下图所示。



ZigBee安全

❖ ZigBee安全体系结构

- IEEE 802.15.4-2003标准定义了最下面的两层：
 - **物理层（PHY）和MAC层。**
- ZigBee联盟在此基础上建立了**网络层（NWK层）和应用层（APL）** 框架。
- PHY层提供基本的物理无线通信能力；
- MAC层提供设备间的可靠性授权和单跳通信连接服务。
- NWK层提供用于构建不同网络拓扑结构的路由和多跳功能
- 应用层的框架包括了应用支持子层（APS）、ZigBee设备对象（ZDO）和由制造商制订的应用对象。
 - ZDO负责所有设备的管理。
 - APS提供ZigBee应用的基础。

ZigBee安全

❖ ZigBee安全体系结构

- ZigBee具体有三层安全机制：MAC、NWK和APL负责各自帧的安全传输。而且，APS子层提供建立和保持安全关系的服务；ZDO管理安全性策略和设备的安全性结构。

ZigBee安全

❖ ZigBee安全体系结构

❖ 安全密钥

- 网络中ZigBee设备中的安全性是以一些“连接”密钥（Link Key）和一个“网络”密钥（Network Key）为基础的。
- 应用层（APL）对等实体间的单播通信的安全性是依靠由两个设备共享的一个128位连接密钥保证的，而广播通信的安全性则是依靠由网络中所有设备共享的一个128位连接密钥保证的，接收方通常知道准确的安全性安排。
- 例如，接收方知道帧是被连接密钥还是网络密钥保护的。

ZigBee安全

❖ ZigBee安全体系结构

❖ 安全密钥

- 设备获得连接密钥可以通过密钥传输、密钥制定或预安装等方式中的任意一种。而网络密钥是通过密钥传输或者预安装的方式获得。用于获取连接密钥的密钥制定技术是基于一个“主”密钥的（Master Key）的。一个设备将通过密钥传输或者预安装的方式获取一个主密钥来制定相应的连接密钥。最后，设备间的安全性就是依靠这些密钥的安全初始化和安装来实现的。
- 网络密钥可能被ZigBee的MAC、NWK和APL层使用，也就是说，相同的网络密钥和相关联的输入/输出帧计数器对所有层都是有效的。

ZigBee安全

❖ ZigBee安全体系结构

➤ 完整性保护

- ◆ ZigBee技术针对不同的应用，提供了不同的安全服务。这些服务分别作用在MAC层、NWK层和APL层上，对数据加密和完整性保护是在CCM*模式下执行AES-128加密算法。
- ◆ CCM*是CCM的增强版本，它包含CCM的所有特征，提供加密和完整性检测功能。
- ◆ CCM模式是由计数器模式和CBC-MAC模式相结合构成的。使用基于CCM*模式的安全级别来保护输入/输出帧，是最基本的安全性需求。与其他安全模式不同，CCM*模式对MAC、NWK、APL层重复使用相同密钥。

ZigBee安全

❖ ZigBee安全体系结构

➤ NWK（网络层）安全

- ◆ 当来自NWK层的帧需要保护，或者来自更高层的帧且网络层信息库（Network Information Base, NIB）中属性为TRUE时，ZigBee使用帧保护机制。
- ◆ NIB中的属性给出保护NWK帧的安全级别。上层通过建立网络密钥，决定使用哪个安全级别来保护NWK层。

ZigBee安全

❖ ZigBee安全体系结构

➤ NWK（网络层）安全

- ◆ 通过多跳连接传送消息是NWK层的一个职责，NWK层会广播路由请求信息并处理收到的路由回复消息。同时，路由请求消息会广播到其他设备，邻近设备则回复路由应答消息。若连接密钥使用适当，NWK层将使用连接密钥保护输出NWK帧的安全，若没有适当的连接密钥，为了保护信息，NWK将使用活动的网络密钥保护输出NWK帧。帧的格式明确给出保护帧的密钥，因此接收方可以推断出处理帧的密钥。

SYNC	PHY Header	MAC Header	NWK Header	Auxiliary Header(AH)	Encrypted MAC Payload	MIC
-------------	-----------------------	-----------------------	-----------------------	---------------------------------	----------------------------------	------------

NWK层安全帧格式

ZigBee安全

❖ ZigBee安全体系结构

➤ APL（应用层）安全

- ◆ 当来自APL层的帧需要安全保护时，APS子层将会处理其安全性。APS（应用支撑子层）的帧保护机制是基于连接密钥或网络密钥的。APS层提供ZDO（ZigBee设备对象）的密钥建立、密钥传输和设备管理等服务。
- ◆ APS提供的安全服务有密钥建立、密钥传输、设备服务管理。密钥建立是在两个设备间进行，包括四个步骤：交换暂时数据，生成共享密钥，获得连续密钥，确认连接密钥。

APL层安全帧格式

ZigBee安全

❖ ZigBee安全体系结构

➤ APL（应用层）安全

- ◆ 密钥传输服务是在设备之间安全传输密钥。
- ✓ 设备服务管理，包括更新设备和移除设备
- ✓ 更新设备服务，提供一种安全通知其他设备有第三方设备需要更新
- ✓ 移除设备，则是通知有设备不满足安全需要，要被删除。

SYNC	PHY Header	MAC Header	NWK Header	APS Header	Auxiliary Header(AH)	Encrypted MAC Payload	MIC
-------------	-----------------------	-----------------------	-----------------------	-----------------------	---------------------------------	----------------------------------	------------

APL层安全帧格式

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC（IEEE 802.15.4）安全

◆ 安全模式

- ✓ 无安全模式，MAC层默认的安全模式。处在这种模式下的设备接收到一个帧时，只检查帧的目的地址。如果对某种应用的安全要求不高时，可采用该模式。
- ✓ 访问控制列表模式，为通信提供访问控制服务。高层可以通过设置MAC子层的ACL（接入控制清单），从而指示MAC子层根据源地址过滤接收到的帧。这种方式下的MAC子层没有提供加密保护，高层需要采取其他机制来保证通信私密性。
- ✓ 安全模式，同时使用访问控制和帧载荷密码保护，提供了较完善的安全服务。

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC（IEEE 802.15.4）安全

◆ 安全服务

- ✓ 访问控制：不对发送和接收的帧进行任何修改和检查，只是让接收帧的设备根据接收帧中的源地址对帧进行过滤。
- ✓ 数据加密：使用指定的密钥对帧中的载荷进行加密处理，并将加密后的数据重新放在帧的载荷部分，帧的其他部分不进行加密处理。加密处理完成后，MAC层将重新计算帧的FCS（帧校验序列）。

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC（IEEE 802.15.4）安全

◆ 安全服务

- 帧完整性：帧完整性提供的安全服务使用消息完整码，可以防止对消息进行非法修改。数据、信标和命令帧均可用MIC保障帧的完整性。
- 序列号更新防重放攻击：MAC层帧头有一个序列号字段，其值为该帧的唯一序列号。设备接收到一个帧后，MAC层管理实体将接收的帧的序列号与保存的序列号做比较。如果接收的序列号比保存的序列号新，则保留、上传接收的帧，同时更新保存的序列号；否则，丢弃该帧。这种方法保证了接收的帧是最新的，能够避免帧重放攻击。

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC（IEEE 802.15.4）安全

◆ MAC安全帧格式

- ✓ 802.15.4 MAC帧主要由报头（MHR）、负载和报尾（MFR）3部分组成（如下图）。报头主要包括帧控制、序列号和地址信息3部分，负载决定于帧类型，报尾是16位CRC。MHR中帧控制字段的安全性启动位表明是否需要对该帧实施安全保护，如果该位被设为1，将使用存储在MAC PIB的安全属性对帧进行相应的安全操作。

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC（IEEE 802.15.4）安全

◆ MAC安全帧格式

MAC报头（MHR）						MAC负载	MAC报尾	
字节数：2	1	0/2	0/2/8	0/2	0/2/8	变量	2	
帧控制	序列号	目的PAN标识	目的地址	源PAN标识	源地址	帧负载	FCS	
位：0-2	3	4	5	6	7-9	10-11	12-13	14-15
帧类型	安全性启动位	等待帧	确认请求	PAN网内	保留位	目的寻址模式	保留位	源寻址模式

MAC帧格式

SYNC	PHY Header	MAC Header	Auxiliary Header(AH)	Encrypted MAC Payload	MIC
-------------	-------------------	-------------------	-----------------------------	------------------------------	------------

MAC层安全帧格式

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC（IEEE 802.15.4）安全

➤ MAC层负责来源于本层的帧的安全性处理，但由上层决定ZigBee使用哪个安全级别，需要安全性处理的MAC层帧会处理安全材料，由上层设置参数使之与活动的网络密钥和NWK层计数器相对应，与APS层中与相邻设备共享的任意连接密钥相对应，安全级别与NIB中属性相对应。

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC（IEEE 802.15.4）安全

◆ MAC PIB安全属性

- ✓ MAC PIB包含了管理MAC子层所需的各类信息（如下表所示）。安全属性包含工作模式、一个默认ACL入口及若干个附加ACL入口，授权执行特定功能的访问控制表ACL提供了设备选择与之通信的其他设备的能力。附加ACL入口包含在macACLEntryDescriptorSet中，可包含255个附加入口，每一个对应于一种可信设备，包含PAN标识符、64位扩展地址、短地址、安全组件及相关加密内容。默认ACL入口包含与附加入口相似的内容。

ZigBee安全

	属 性		功 能 描 述
安全模式	macSecurityMode		安全模式标识符
入口	macDefaultSecurity		指示没有列举在附加ACL入口中的设备是否能传输/接收安全帧
	macDefaultSecuritySuite		默认安全组件标识符
	macDefaultSecurityMaterialLength		macDefaultSecurityMaterial中包含的字节数目
	macDefaultSecurityMaterial		特定安全加密内容用于保护不在附加ACL中的MAC帧
入口	DescriptorSet	macACLEntryDeseriprorSetSize	附加ACL入口的数目
		ACLExtendedAddress ACL	ACL设备64位IEEE扩展地址
		ACLShortAddress	ACL设备16位短地址
		ACL PANId	ACL设备16位LR-WPAN标识符
		ACLSecuritySuite	保护ACLExtendedAddress中指定设备之间通信的安全组件标识符
		ACLSecurityMaterialLength	ACLSecurityMaterial中包含的字节数目
		ACLSecurityMaterial	特定安全加密内容，用于保护与ACLExtended Address中指定设备之间的MAC帧

MAC PIB安全属性

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC（IEEE 802.15.4）安全

◆ 安全组件

- ✓ 安全组件是给MAC帧提供安全服务的一系列操作，802.15.4标准中含有8种组件，如下表所示，None表明不执行任何安全操作。安全组件中提供帧完整性安全服务的AES-CBC-MAC和AES-CCM根据计算MIC的长度分为3种：32比特、64比特、128比特。所有的安全组件使用的算法是AES，在智能卡等8位及PC等32位处理器上性能均表现优秀。

ZigBee安全

安全组件	安全服务			
	访问控制	数据加密	帧完整性	序列更新
None				
AES-CTR	√	√		√
AES-CBC-MAC-32	√		√	
AES-CBC-MAC-64	√		√	
AES-CBC-MAC-128	√		√	
AES-CCM-32	√	√	√	√
AES-CCM-64	√	√	√	√
AES-CCM-128	√	√	√	√

安全组件分类

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC（IEEE 802.15.4）安全

◆ 安全方案

- ✓ 当MAC层按上层要求对传输的帧进行安全处理时，MAC层按指定的安全方案实现相应的安全服务。安全方案的名称指明了对称加密算法、模式、完整性检验位长度等。CCM是MAC层安全方案中的一种，提供了全部4种安全服务，由计数（CTR）模式和密码分组链接消息鉴别码（CBC-MAC）相结合构成。该算法首先利用CBC-MAC计算MIC，然后用CTR对MIC和明文数据进行加密，输出择优加密的数据和加密的MIC组成。在CCM算法中，要确定两个参数。第1个是认证字段的长度M，即选取的MIC长度，第2个是表示消息字段的长度L。

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC (IEEE 802.15.4) 安全

◆ 标准安全模式下输出帧的处理流程 (参考下图)

- 管理实体MLME从高层收到准备进行安全帧的传输消息后，扫描ACL (接入控制清单) 入口以发现macACLEntry — DescriptorSet中ACLPANId、ACLExtendedAddress或ACLShortAddress字段与创建帧的目的地址信息相匹配的入口。
- 如果发现匹配，MLME将从相关的ACLSecurity — Suite字段中选择安全组件，ACLSecurityMaterial字段选择安全加密内容。如果不能定位相匹配的ACL入口，MLME将检查macDefaultSecurity。

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC (IEEE 802.15.4) 安全

◆ 标准安全模式下输出帧的处理流程 (参考下图)

- ✓ 如果macDefaultSecurity为TRUE, MLME从macDefaultSecuritySuite中选择安全组件, 从macDefaultSecurityMaterial中选择安全内容。如果macDefaultSecurity为FALSE, MLME将通知高层。
- ✓ 在MLME从ACL中获得合适的安全组件及安全内容后, 首先将帧控制字段的安全性启动位设为1, 然后对帧进行相应的安全操作。
- ✓ 如果安全组件指明使用加密 (AES-CTR), 对帧负载字段中的数据加密后放入相应位置。
- ✓ 如果安全组件指明使用完整码 (AES-CBC-MAC), 则应对帧的MHR和负载链接起来计算并将结果放入相应位置。

ZigBee安全

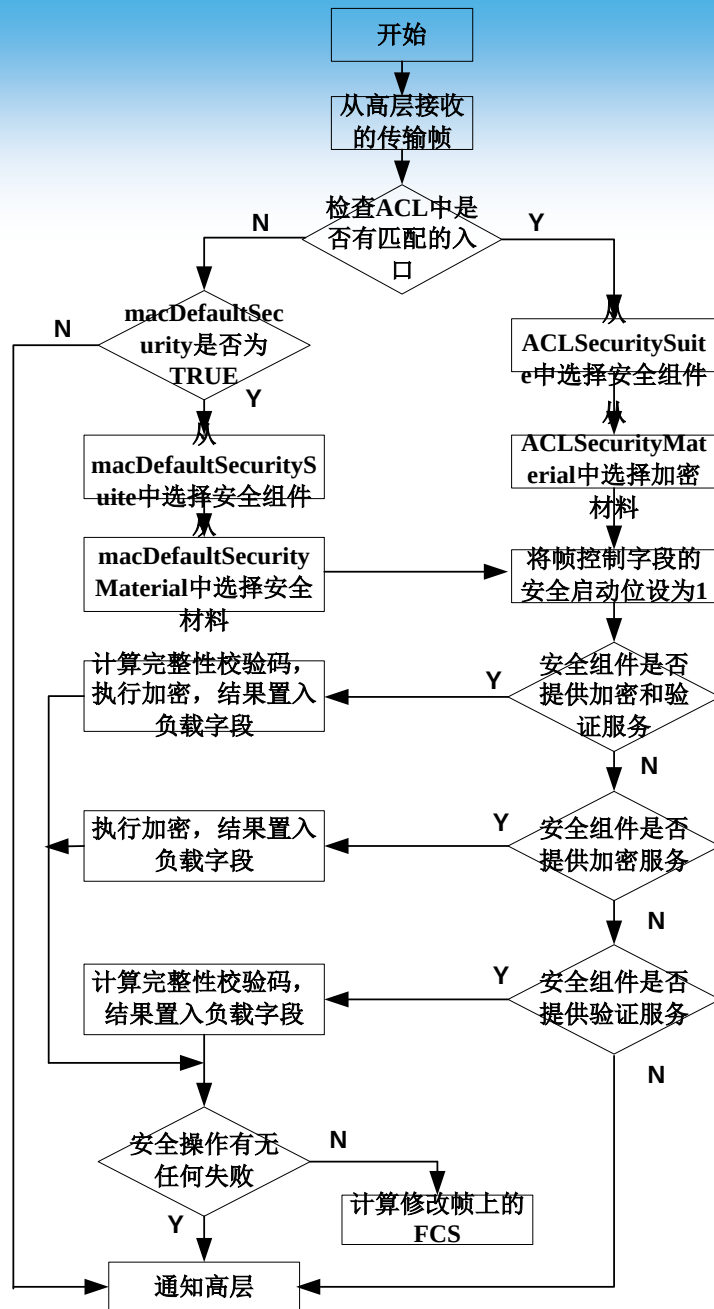
❖ ZigBee安全体系结构

➤ MAC (IEEE 802.15.4) 安全

◆ 标准安全模式下输出帧的处理流程 (参考下图)

- 如果安全操作中有任何失败，MLME将通知高层。如果安全性操作成功被执行，MAC负载字段做相应修改，设备将计算修改帧上的FCS。

安全模式下输出帧的处理流程



ZigBee安全

❖ ZigBee安全体系结构

➤ MAC（IEEE 802.15.4）安全

◆ 标准安全模式

- ✓ 安全模式对输入帧的解密处理和加密操作类似，MLME在收到帧时首先要检查安全启动位的设置情况，如果为0则通知高层，如果为1则通过ACL或默认入口找到相应的安全组件和安全内容，然后执行相应的解密及完整性校验。如果至少有一个安全操作失败，设备MLME将丢弃帧并通知高层。如果安全操作成功执行，MAC负载字段恢复为加密的原始状态，设备继续帧的后续处理。

ZigBee安全

❖ ZigBee安全体系结构

➤ MAC（IEEE 802.15.4）安全

◆ 安全缺陷

- ✓ Sastry和Wagner给出了对IEEE 802.15.4的安全分析，指出协议中存在的一些问题，如IV管理问题：在多个ACL记录中使用相同的密钥；因为电源中断导致ACL状态的丢失。
- ❑ 密钥管理问题：不支持组密钥；网络共享密钥与重放攻击保护不兼容；对（Pairwise）密钥的支持不充分。
- ❑ 完整性保护不充分：加密模式没有认证；AES-CTR存在拒绝服务攻击；对确认包没有完整性保护。